



Herzlich Willkommen Block 4

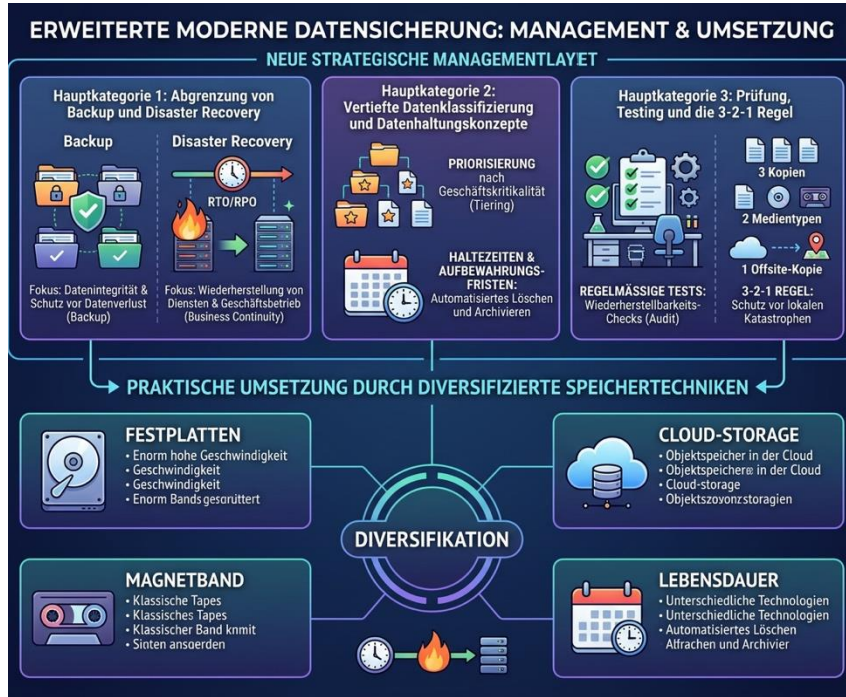
Archivierung - Backup- und Restore Lösungen
ABRL.TA1A



Mai 2026 / Mevluet Polat

Agenda

Inhaltsübersicht Unit 4



Abgrenzung von Backup und Disaster Recovery

Vertiefte Datenklassifizierung und Datenhaltungskonzepte

Prüfung, Testing und die 3-2-1 Regel

Abgrenzung von Backup und Disaster Recovery

Grundkonzepte Backup



Datensicherung: Regelmässige Kopien schützen die betrieblichen Kerninformationen effektiv vor dem versehentlichen oder mutwilligen Löschen.

Versionierung: Die Speicherung verschiedener Dateiversionen ermöglicht eine schnelle Wiederherstellung von vorherigen intakten digitalen Arbeitsständen.

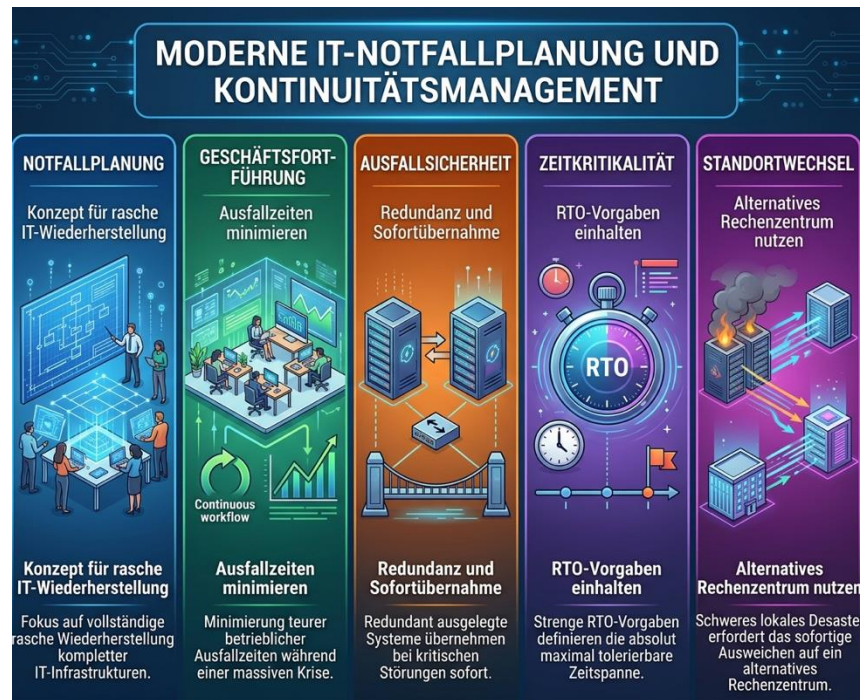
Zeiträumen: Ein klassisches Backup orientiert sich stark an festgelegten RPO-Vorgaben für den regulären Geschäftsbetrieb.

Granularität: Die Wiederherstellung einzelner verlorener Dateien erfolgt meist gezielt aus einem bestehenden gesicherten Datenarchiv.

Fokus: Der primäre Zweck liegt in der langfristigen Konservierung von wichtigen operativen elektronischen Geschäftsdokumenten.

Abgrenzung von Backup und Disaster Recovery

Grundkonzepte Disaster Recovery



Notfallplanung: Ein durchdachtes Konzept fokussiert sich primär auf die vollständige rasche Wiederherstellung kompletter IT-Infrastrukturen.

Geschäftsfortführung: Das oberste Ziel ist die Minimierung teurer betrieblicher Ausfallzeiten während einer massiven Krise.

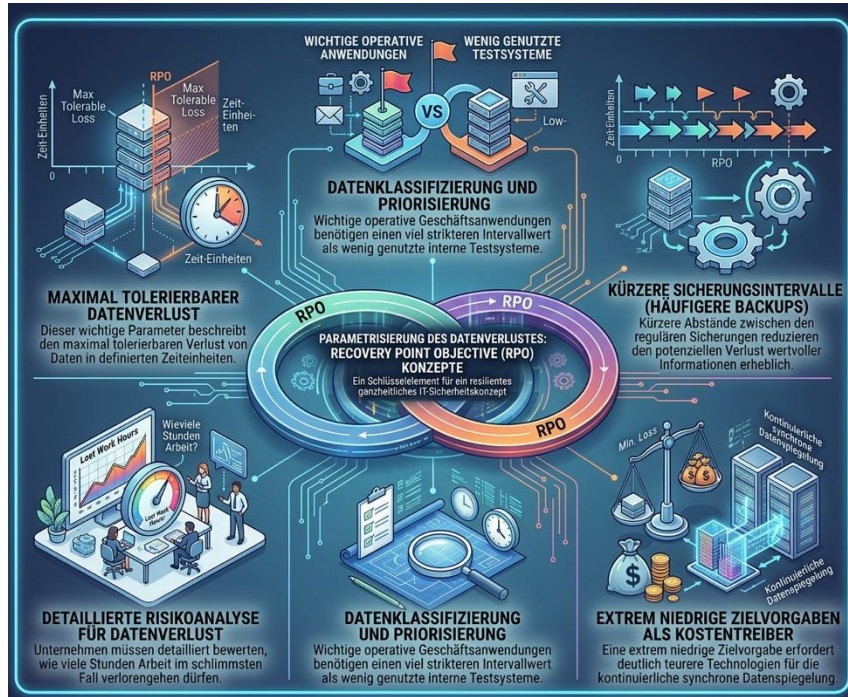
Ausfallsicherheit: Redundant ausgelegte Systeme übernehmen bei kritischen Störungen sofort die Arbeit der ausgefallenen Hauptkomponenten.

Zeitkritikalität: Strenge RTO-Vorgaben definieren die absolut maximal tolerierbare Zeitspanne bis zur vollständigen Systemwiederherstellung zwingend.

Standortwechsel: Ein schweres lokales Desaster erfordert meist das sofortige Ausweichen auf ein alternatives Rechenzentrum.

Abgrenzung von Backup und Disaster Recovery

RPO im Kontext von Backup



Datenverlust: Dieser wichtige Parameter beschreibt den maximal tolerierbaren Verlust von Daten in definierten Zeiteinheiten.

Sicherungsintervall: Kürzere Abstände zwischen den regulären Sicherungen reduzieren den potenziellen Verlust wertvoller Informationen erheblich.

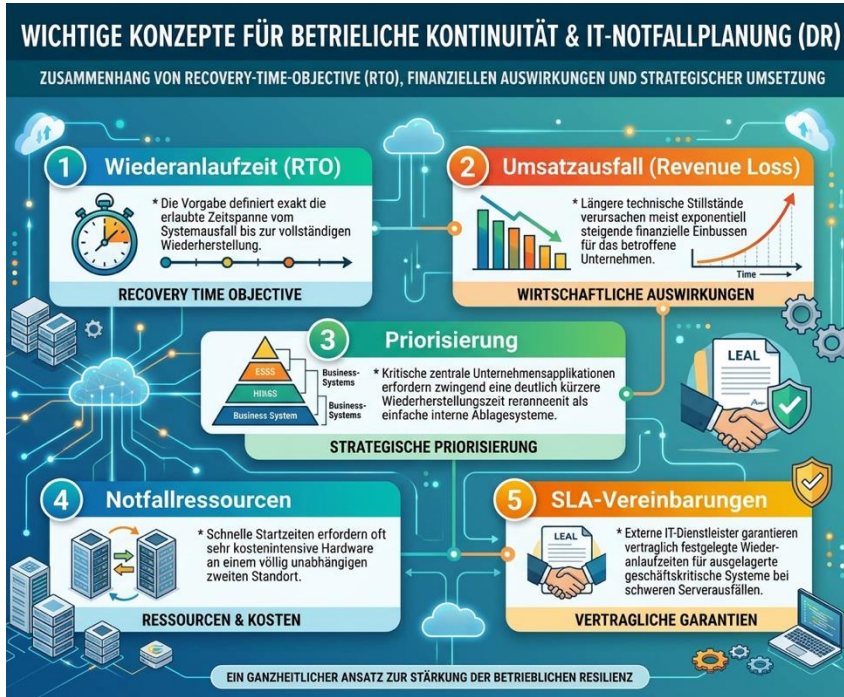
Kostentreiber: Eine extrem niedrige Zielvorgabe erfordert deutlich teurere Technologien für die kontinuierliche synchrone Datenspiegelung.

Risikoanalyse: Unternehmen müssen detailliert bewerten, wie viele Stunden Arbeit im schlimmsten Fall verlorengehen dürfen.

Klassifizierung: Wichtige operative Geschäftsanwendungen benötigen einen viel strikteren Intervallwert als wenig genutzte interne Testsysteme.

Abgrenzung von Backup und Disaster Recovery

RTO im Kontext von Disaster Recovery



Wiederanlaufzeit: Die Vorgabe definiert exakt die erlaubte Zeitspanne vom Systemausfall bis zur vollständigen Wiederherstellung.

Umsatzausfall: Längere technische Stillstände verursachen meist exponentiell steigende finanzielle Einbußen für das betroffene Unternehmen.

Priorisierung: Kritische zentrale Unternehmensapplikationen erfordern zwingend eine deutlich kürzere Wiederherstellungszeit als einfache interne Ablagesysteme.

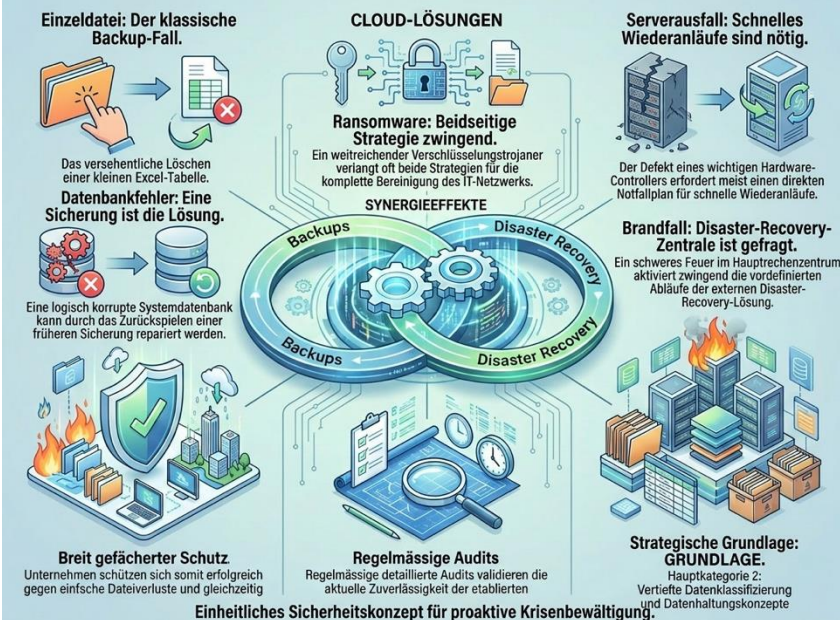
Notfallressourcen: Schnelle Startzeiten erfordern oft sehr kostenintensive Hardware an einem völlig unabhängigen zweiten Standort.

SLA-Vereinbarungen: Externe IT-Dienstleister garantieren vertraglich festgelegte Wiederanlaufzeiten für ausgelagerte geschäftskritische Systeme bei schweren Serverausfällen.

Abgrenzung von Backup und Disaster Recovery

Vergleich der Anwendungsfälle

ZUSAMMENHANG VON DATENSICHERUNGS- UND GESCHÄFTSKONTINUITÄTSSTRATEGIEN FÜR EIN RESILIENTES GANZHEITLICHES IT-SICHERHEITSKONZEPT.



Einzeldatei: Das versehentliche Löschen einer kleinen Excel-Tabelle ist ein ganz klassischer Fall für Backups.

Serverausfall: Der Defekt eines wichtigen Hardware-Controllers erfordert meist einen direkten Notfallplan für schnelle Wiederanläufe.

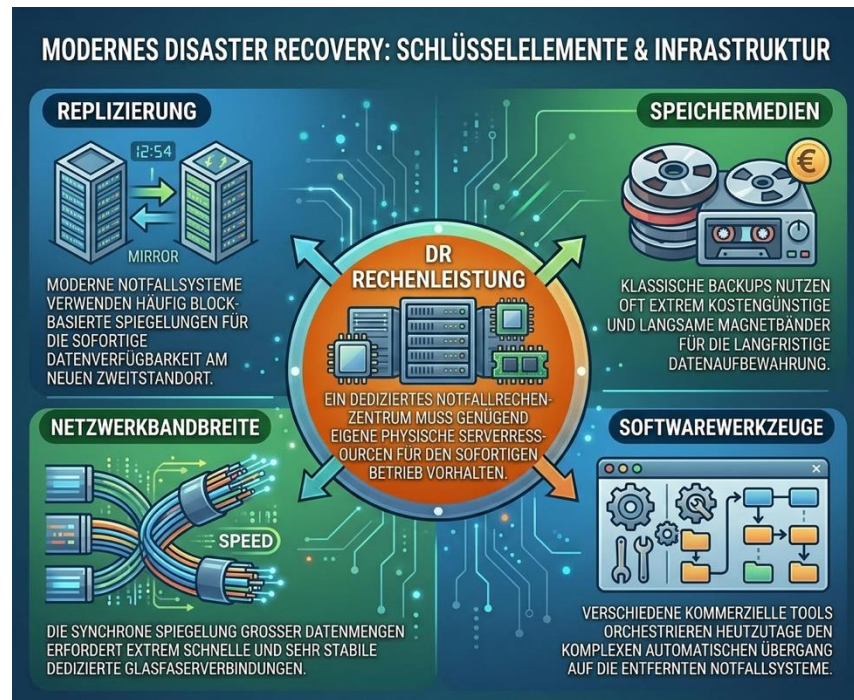
Ransomware: Ein weitreichender Verschlüsselungstrojaner verlangt oft beide Strategien für die komplette Bereinigung des IT-Netzwerks.

Brandfall: Ein schweres Feuer im Hauptrechenzentrum aktiviert zwingend die vordefinierten Abläufe der externen Disaster-Recovery-Lösung.

Datenbankfehler: Eine logisch korrupte Systemdatenbank kann durch das Zurückspielen einer früheren Sicherung repariert werden.

Abgrenzung von Backup und Disaster Recovery

Technische Abgrenzung



Speichermedien: Klassische Backups nutzen oft extrem kostengünstige und langsame Magnetbänder für die langfristige Datenaufbewahrung.

Replizierung: Moderne Notfallsysteme verwenden häufig blockbasierte Spiegelungen für die sofortige Datenverfügbarkeit am neuen Zweitstandort.

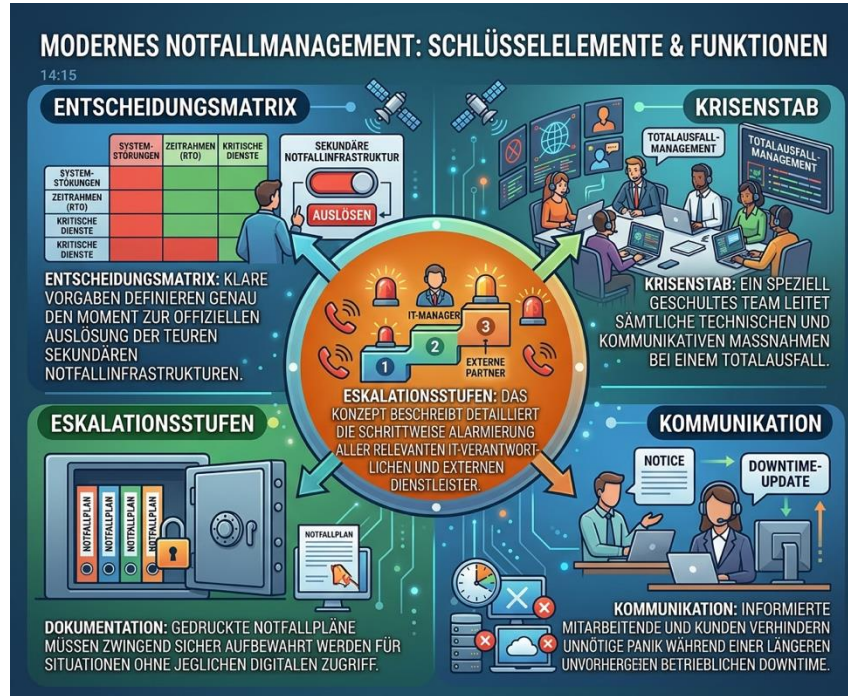
Rechenleistung: Ein dediziertes Notfallrechenzentrum muss genügend eigene physische Serverressourcen für den sofortigen Betrieb vorhalten.

Netzwerkbandbreite: Die synchrone Spiegelung grosser Datenmengen erfordert extrem schnelle und sehr stabile dedizierte Glasfaserverbindungen.

Softwarewerkzeuge: Verschiedene kommerzielle Tools orchestrieren heutzutage den komplexen automatischen Übergang auf die entfernten Notfallsysteme.

Abgrenzung von Backup und Disaster Recovery

Organisatorische Aspekte im Ernstfall



Entscheidungsmatrix: Klare Vorgaben definieren genau den Moment zur offiziellen Auslösung der teuren sekundären Notfallinfrastrukturen.

Krisenstab: Ein speziell geschultes Team leitet sämtliche technischen und kommunikativen Massnahmen bei einem Totalausfall.

Eskalationsstufen: Das Konzept beschreibt detailliert die schrittweise Alarmierung aller relevanten IT-Verantwortlichen und externen Dienstleister.

Kommunikation: Informierte Mitarbeitende und Kunden verhindern unnötige Panik während einer längeren unvorhergesehenen betrieblichen Downtime.

Dokumentation: Gedruckte Notfallpläne müssen zwingend sicher aufbewahrt werden für Situationen ohne jeglichen digitalen Zugriff.

Abgrenzung von Backup und Disaster Recovery

Fallstricke bei der Unterscheidung



Fehlannahmen: Ein funktionierendes Datenbackup garantiert niemals automatisch die schnelle vollständige Wiederherstellung des gesamten Serverbetriebs.

Abhängigkeiten: Die alleinige Wiederherstellung der Datenbank nützt nichts ohne den funktionierenden dazugehörigen betrieblichen Applikationsserver.

Testmangel: Ungenügend simulierte Ausfälle führen oft zu massiven unerwarteten Problemen während eines echten Notfalls.

Kapazitätsengpässe: Das Ausweichrechenzentrum muss die reguläre tägliche Produktionslast des Unternehmens ohne massive Leistungseinbussen bewältigen.

Netzwerkrouen: Komplexe DNS-Umstellungen werden in der anfänglichen Planung für das Disaster-Recovery sehr oft vergessen.

Abgrenzung von Backup und Disaster Recovery

Zusammenführung der Konzepte



Synergieeffekte: Beide Strategien ergänzen sich gegenseitig zu einem äusserst widerstandsfähigen ganzheitlichen betrieblichen IT-Sicherheitskonzept optimal.

Cloud-Lösungen: Moderne externe Rechenzentren bieten kombinierte intelligente Dienste für Backups und sofortige Systemausfallübernahmen an.

Automatisierung: Softwaregestützte Prozesse verbinden regelmässige sichere Datensicherungen direkt mit den Vorbereitungen für kritische Serverausfälle.

Risikominimierung: Unternehmen schützen sich somit erfolgreich gegen einfache Dateiverluste und gleichzeitig gegen existenzbedrohende Katastrophen.

Überprüfung: Regelmässige detaillierte Audits validieren die aktuelle Zuverlässigkeit der etablierten Verzahnung beider komplexer Notfallkonzepte.

Gruppenaufgabe 1 (20 Minuten)

Abgrenzung von Backup und Disaster Recovery

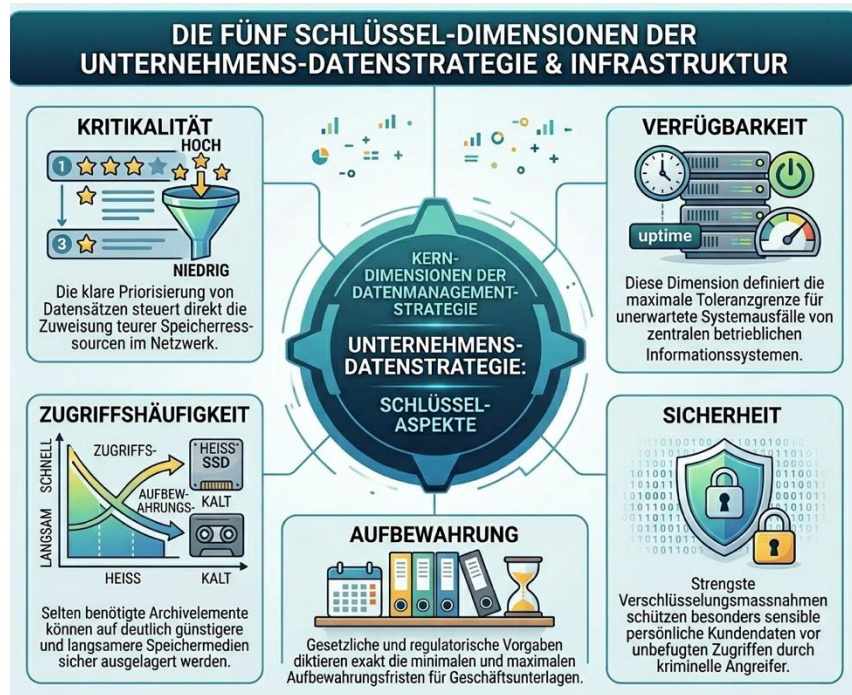
Szenario:Die «AlpinTech GmbH» hat nach einem Serverausfall festgestellt, dass ihr bisheriges Backup-Konzept nicht ausreicht, um die Produktion schnell genug wieder hochzufahren. Das Management fordert nun eine klare Trennung und Neudefinition der Backup- und Disaster-Recovery-Prozesse. Als IT-Beratungsteam wurden Sie beauftragt, die bestehenden RPO- und RTO-Anforderungen zu analysieren und eine strukturierte Handlungsempfehlung zu erarbeiten.

Arbeitsauftrag:Erstellen Sie für die «AlpinTech GmbH» ein Abgrenzungsdokument. Definieren Sie für drei Abteilungen (Produktion, Buchhaltung, Marketing) spezifische RPO- und RTO-Ziele. Leiten Sie daraus ab, in welchen Fällen ein klassisches Backup reicht und wann zwingend ein Disaster-Recovery-Plan greifen muss.

Ergebnis:Bereiten Sie eine Kurzpräsentation (ca. 5 Minuten) mit einem Handout vor, welches die RPO/RTO-Matrix und die abgeleiteten Notfallprozesse für das Management übersichtlich darstellt.

Vertiefte Datenklassifizierung

Dimensionen der Datenklassifizierung



Verfügbarkeit: Diese Dimension definiert die maximale Toleranzgrenze für unerwartete Systemausfälle von zentralen betrieblichen Informationssystemen.

Sicherheit: Strengste Verschlüsselungsmassnahmen schützen besonders sensible persönliche Kundendaten vor unbefugten Zugriffen durch kriminelle Angreifer.

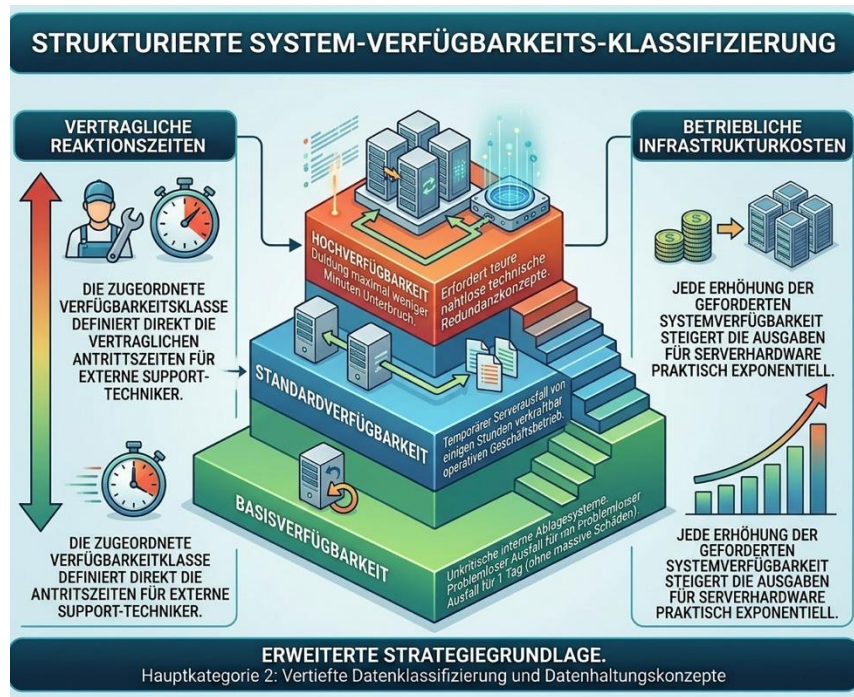
Aufbewahrung: Gesetzliche und regulatorische Vorgaben diktiert exakt die minimalen und maximalen Aufbewahrungsfristen für Geschäftsunterlagen.

Kritikalität: Die klare Priorisierung von Datensätzen steuert direkt die Zuweisung teurer Speicherressourcen im Netzwerk.

Zugriffshäufigkeit: Selten benötigte Archivelemente können auf deutlich günstigere und langsamere Speichermedien sicher ausgelagert werden.

Vertiefte Datenklassifizierung

Klassen der Verfügbarkeit



Hochverfügbarkeit: Diese Systeme dulden maximal wenige Minuten Unterbruch und erfordern teure nahtlose technische Redundanzkonzepte.

Standardverfügbarkeit: Ein temporärer Serverausfall von einigen Stunden ist für den operativen regulären Geschäftsbetrieb verkraftbar.

Basisverfügbarkeit: Diese unkritischen internen Ablagesysteme können problemlos für einen Tag ausfallen ohne massive Schäden.

Reaktionszeiten: Die zugeordnete Verfügbarkeitsklasse definiert direkt die vertraglichen Antrittszeiten für die externen hochspezialisierten Support-Techniker.

Infrastrukturkosten: Jede Erhöhung der geforderten Systemverfügbarkeit steigert die betrieblichen Ausgaben für Serverhardware praktisch exponentiell.

Vertiefte Datenklassifizierung

Klassen der Sicherheit

DATENKLASSIFIZIERUNG & INFORMATIONSSICHERHEITSRICHTLINIEN

ÖFFENTLICH
Öffentlich: Diese allgemeinen Marketinginformationen unterliegen keinen speziellen Zugangsbeschränkungen und dürfen weltweit frei publiziert werden.



INTERN
Intern: Der Zugriff auf diese regulären betrieblichen Dokumente ist ausschliesslich auf registrierte Unternehmensmitarbeitende beschränkt.



VERTRAULICH
Vertraulich: Wichtige Personaldaten und Finanzberichte erfordern strikte Zugriffskontrollen und zwingend sichere verschlüsselte digitale Dateiablagen.



STRENG-GEHEIM
Streng-Geheim: Hochsensible strategische Geschäftsgeheimnisse benötigen absolute Isolation und dürfen das Firmennetzwerk niemals unverschlüsselt verlassen.



BERECHTIGUNGEN
Berechtigungen: Rollenbasierte Zugriffssysteme garantieren die technische Einhaltung dieser Vorgaben zuverlässig und revisionssicher im Betrieb.



SICHERE DATENHALTUNG
IM UNTERNEHMEN

Öffentlich: Diese allgemeinen Marketinginformationen unterliegen keinen speziellen Zugangsbeschränkungen und dürfen weltweit frei publiziert werden.

Intern: Der Zugriff auf diese regulären betrieblichen Dokumente ist ausschliesslich auf registrierte Unternehmensmitarbeitende beschränkt.

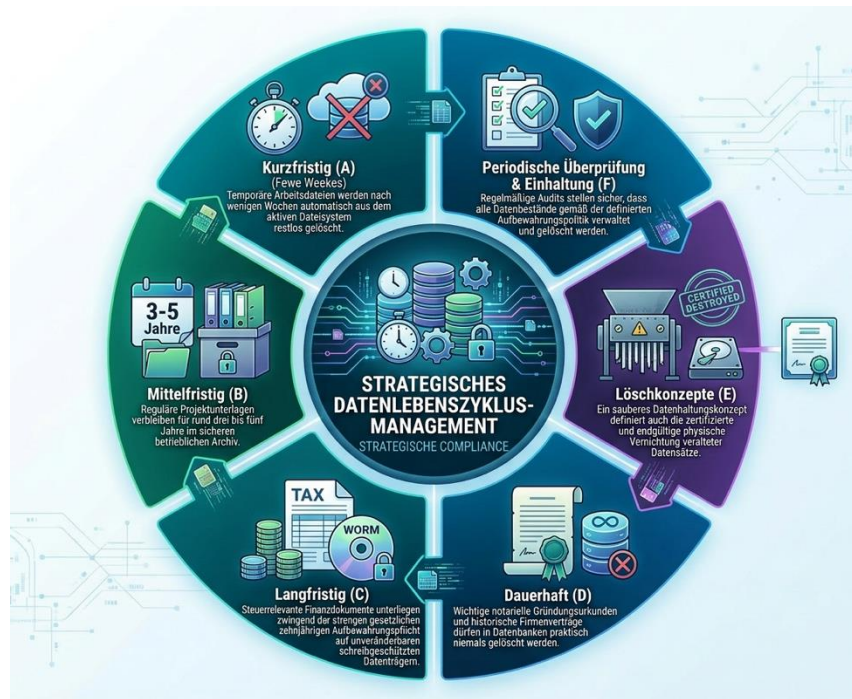
Vertraulich: Wichtige Personaldaten und Finanzberichte erfordern strikte Zugriffskontrollen und zwingend sichere verschlüsselte digitale Dateiablagen.

Streng-Geheim: Hochsensible strategische Geschäftsgeheimnisse benötigen absolute Isolation und dürfen das Firmennetzwerk niemals unverschlüsselt verlassen.

Berechtigungen: Rollenbasierte Zugriffssysteme garantieren die technische Einhaltung dieser Vorgaben zuverlässig und revisionssicher im Betrieb.

Vertiefte Datenklassifizierung

Klassen der Aufbewahrung (Retention)



Kurzfristig: Temporäre Arbeitsdateien werden nach wenigen Wochen automatisch aus dem aktiven Dateisystem restlos gelöscht.

Mittelfristig: Reguläre Projektunterlagen verbleiben für rund drei bis fünf Jahre im sicheren betrieblichen Archiv.

Langfristig: Steuerrelevante Finanzdokumente unterliegen zwingend der strengen gesetzlichen zehnjährigen Aufbewahrungspflicht auf unveränderbaren schreibgeschützten Datenträgern.

Dauerhaft: Wichtige notarielle Gründungsurkunden und historische Firmenverträge dürfen in Datenbanken praktisch niemals gelöscht werden.

Löschkonzepte: Ein sauberes Datenhaltungskonzept definiert auch die zertifizierte und endgültige physische Vernichtung veralteter Datensätze.

Vertiefte Datenklassifizierung

Das Datenhaltungskonzept erstellen

GRUNDLAGEN & PROZESSE DER DATENKLASSIFIZIERUNG



Inventarisierung: Der erste grundlegende Schritt umfasst die detaillierte Katalogisierung sämtlicher vorhandener Applikationen und Datensammlungen.

Klassierung: Jeder identifizierte Datenbestand erhält spezifische definierte Werte für seine Verfügbarkeit, Sicherheit und Aufbewahrungsdauer.

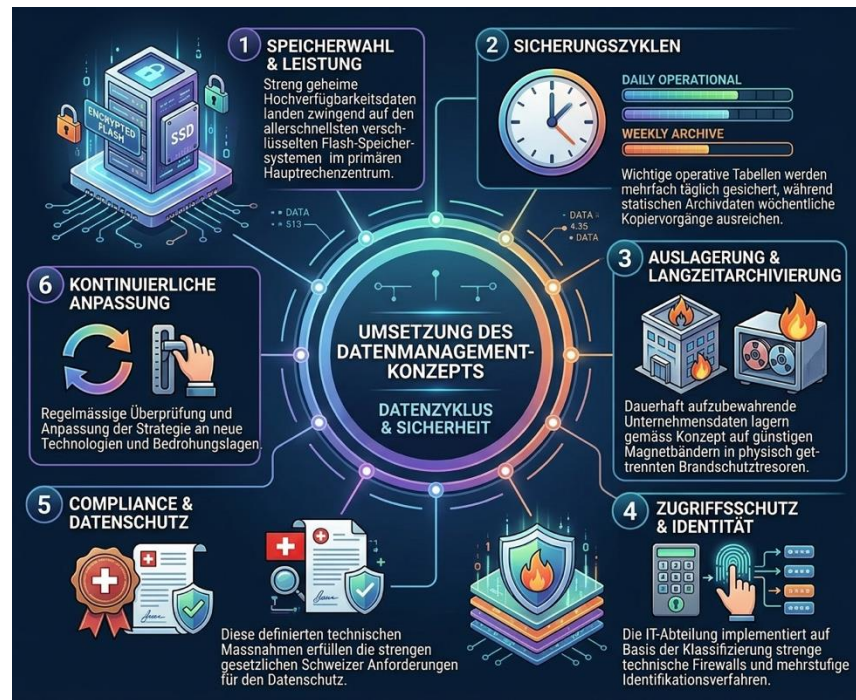
Regelwerk: Diese dokumentierten Vorgaben bilden das verbindliche betriebliche Fundament für alle späteren IT-technischen Backup-Architekturen.

Lebenszyklus: Daten durchlaufen verschiedene vordefinierte Phasen von der Entstehung bis zur endgültigen sicheren Löschung.

Stakeholder: Die Einbindung der jeweiligen Fachabteilungen ist essenziell für die korrekte Definition dieser Einstufungen.

Vertiefte Datenklassifizierung

Ableitung verbindlicher Vorgaben



Speicherwahl: Streng geheime Hochverfügbarkeitsdaten landen zwingend auf den allerschnellsten verschlüsselten Flash-Speichersystemen im primären Hauptrechenzentrum.

Sicherungszyklen: Wichtige operative Tabellen werden mehrfach täglich gesichert, während statischen Archivdaten wöchentliche Kopiervorgänge ausreichen.

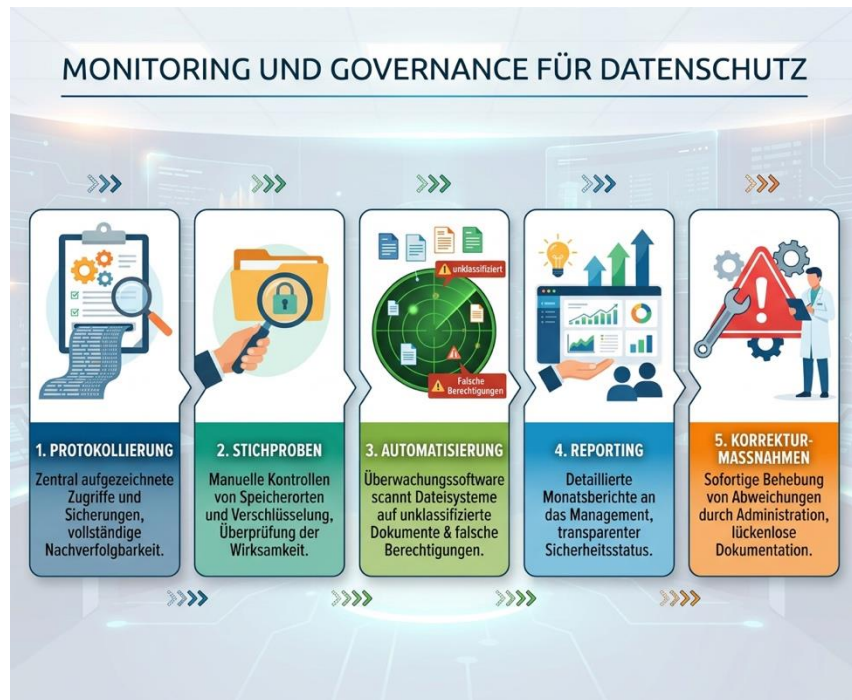
Auslagerung: Dauerhaft aufzubewahrende Unternehmensdaten lagern gemäss Konzept auf günstigen Magnetbändern in physisch getrennten Brandschutztresoren.

Zugriffsschutz: Die IT-Abteilung implementiert auf Basis der Klassifizierung strenge technische Firewalls und mehrstufige Identifikationsverfahren.

Compliance: Diese definierten technischen Massnahmen erfüllen die strengen gesetzlichen Schweizer Anforderungen für den Datenschutz.

Vertiefte Datenklassifizierung

Prüfung der Einhaltung (Auditierung)



Protokollierung: Alle Zugriffe und Sicherungsvorgänge werden zentral aufgezeichnet, um später eine vollständige Nachverfolgbarkeit sicherzustellen.

Stichproben: Regelmässige manuelle Kontrollen überprüfen, ob die vordefinierten Speicherorte und Verschlüsselungen wirklich korrekt funktionieren.

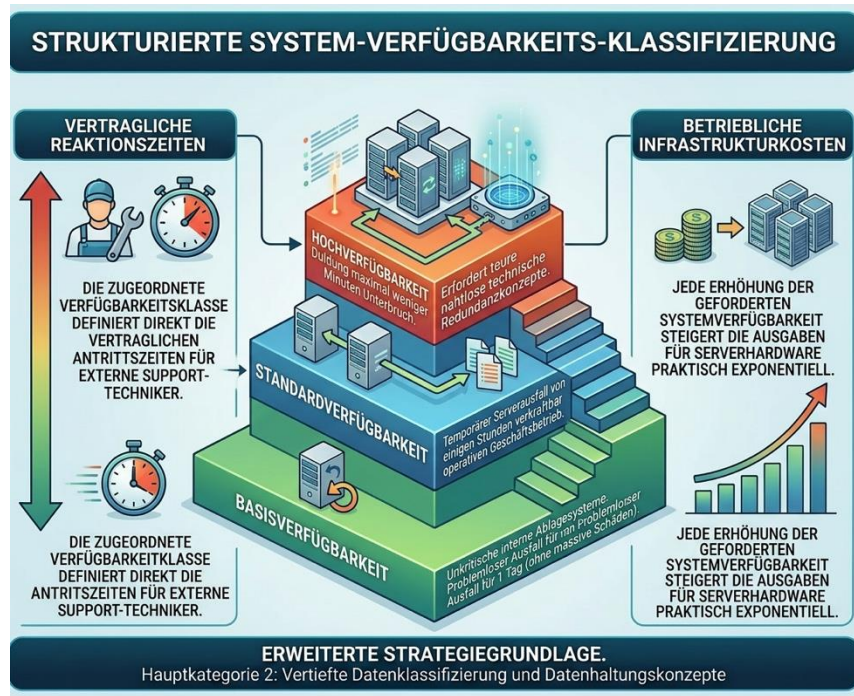
Automatisierung: Spezielle Überwachungssoftware scannt die Dateisysteme auf unklassifizierte Dokumente oder falsch zugewiesene interne Zugriffsberechtigungen.

Reporting: Detaillierte Monatsberichte informieren das Management transparent über den aktuellen Sicherheitsstatus der klassifizierten Datenbestände.

Korrekturmaßnahmen: Gefundene Abweichungen im Konzept müssen sofort durch die Systemadministration behoben und dokumentiert werden.

Vertiefte Datenklassifizierung

Herausforderungen der Klassifizierung



Datenwachstum: Die schiere Menge an neuen Informationen erschwert die kontinuierliche korrekte Einstufung durch Mitarbeitende.

Subjektivität: Verschiedene Fachabteilungen bewerten die Wichtigkeit ihrer Dokumente oftmals sehr unterschiedlich und zu hoch.

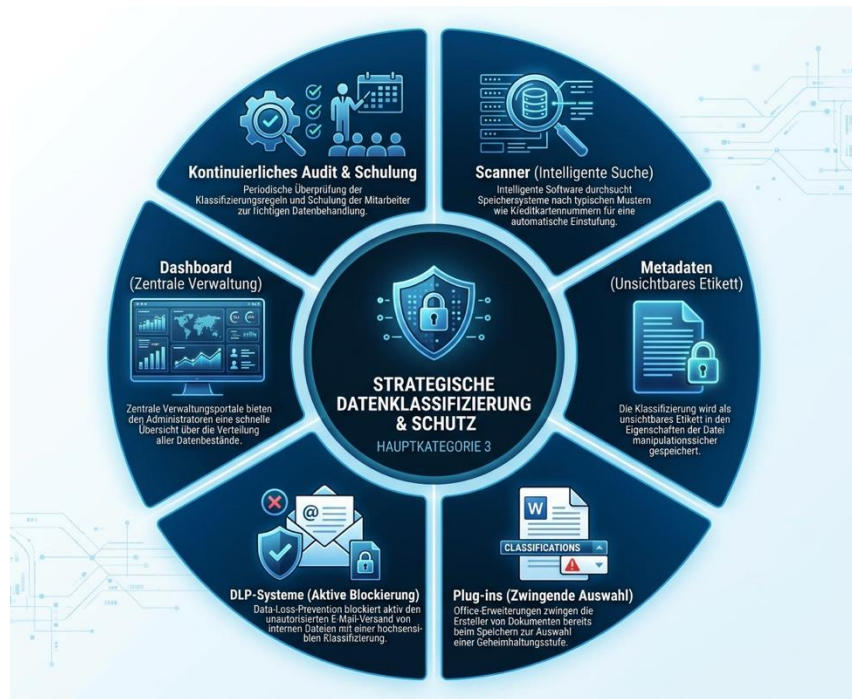
Änderungsmanagement: Die Sensibilität von speziellen Projektdateien kann sich im Laufe der Zeit massiv verändern.

Komplexität: Ein zu detailliertes Klassifizierungssystem überfordert Endanwender und führt zu fehlerhaften oder ignorierten Eingaben.

Migration: Die nachträgliche saubere Klassierung historischer bestehender Datenbestände erfordert enorme zeitliche und personelle Ressourcen.

Vertiefte Datenklassifizierung

Tool-Unterstützung



Scanner: Intelligente Software durchsucht Speichersysteme nach typischen Mustern wie Kreditkartennummern für eine automatische Einstufung.

Metadaten: Die Klassifizierung wird als unsichtbares Etikett in den Eigenschaften der Datei manipulationssicher gespeichert.

Plug-ins: Office-Erweiterungen zwingen die Ersteller von Dokumenten bereits beim Speichern zur Auswahl einer Geheimhaltungsstufe.

DLP-Systeme: Data-Loss-Prevention blockiert aktiv den unautorisierten E-Mail-Versand von internen Dateien mit einer hochsensiblen Klassifizierung.

Dashboard: Zentrale Verwaltungsportale bieten den Administratoren eine schnelle Übersicht über die Verteilung aller Datenbestände.

Hauptkategorie 3: Prüfung, Testing und die 3-2-1 Regel

Gruppenaufgabe 2 (20 Minuten)

Vertiefte Datenklassifizierung und Datenhaltungskonzepte

Szenario: Die «HelveticFinance AG» ist ein mittelständischer Finanzdienstleister. Kürzlich gab es einen Audit-Mangel, da Kundendaten, Marketingbroschüren und historische Buchhaltungsdaten unsortiert auf denselben teuren Hochleistungsservern lagen und alle gleichermassen ohne Löschkonzept gesichert wurden. Als Projektleitung für Data Governance müssen Sie ein neues Datenhaltungskonzept einführen, um rechtliche Vorgaben zu erfüllen und Speicherkosten zu senken.

Arbeitsauftrag: Entwickeln Sie für die «HelveticFinance AG» ein initiales Datenhaltungskonzept. Klassifizieren Sie drei beispielhafte Datenarten (Kreditdossiers, Werbeflyer, E-Mail-Postfächer) anhand der besprochenen Parameter. Legen Sie verbindliche Vorgaben fest, wie und wo diese Daten gespeichert, gesichert und wann sie gelöscht werden müssen.

Ergebnis: Erstellen Sie ein strukturiertes Plakat oder digitales Whiteboard, das Ihre Klassifizierungsmatrix zeigt und präsentieren Sie Ihre abgeleiteten technischen Massnahmen in einem Pitch von maximal 4 Minuten.

Prüfung, Testing und die 3-2-1 Regel

Das 3-2-1 Prinzip repetieren und erweitern



Grundregel: Unternehmen müssen zwingend drei unabhängige Kopien ihrer gesamten wichtigen Daten für Notfälle bereithalten.

Medientypen: Zwei Backups müssen auf völlig unterschiedlichen physikalischen Speichermedien wie Festplatten und Magnetbändern liegen.

Auslagerung: Mindestens eine Kopie muss zwingend an einem geografisch komplett getrennten Aussenstandort aufbewahrt werden.

Offline-Kopie: Moderne Erweiterungen fordern zusätzlich ein völlig isoliertes System zum Schutz vor heimtückischer Ransomware.

Fehlerfreiheit: Die Erweiterung der klassischen Regel verlangt eine garantiert fehlerfreie und erfolgreich getestete Datenwiederherstellung.

Prüfung, Testing und die 3-2-1 Regel

Das 3-2-1-1-0 Konzept



Erweiterung: Moderne Ransomware-Angriffe erzwingen ein Update der traditionellen Basisregeln für eine deutlich erhöhte Sicherheit.

Offline-Airgap: Eine Kopie verbleibt physisch komplett isoliert vom regulären Netzwerk und ist absolut unangreifbar.

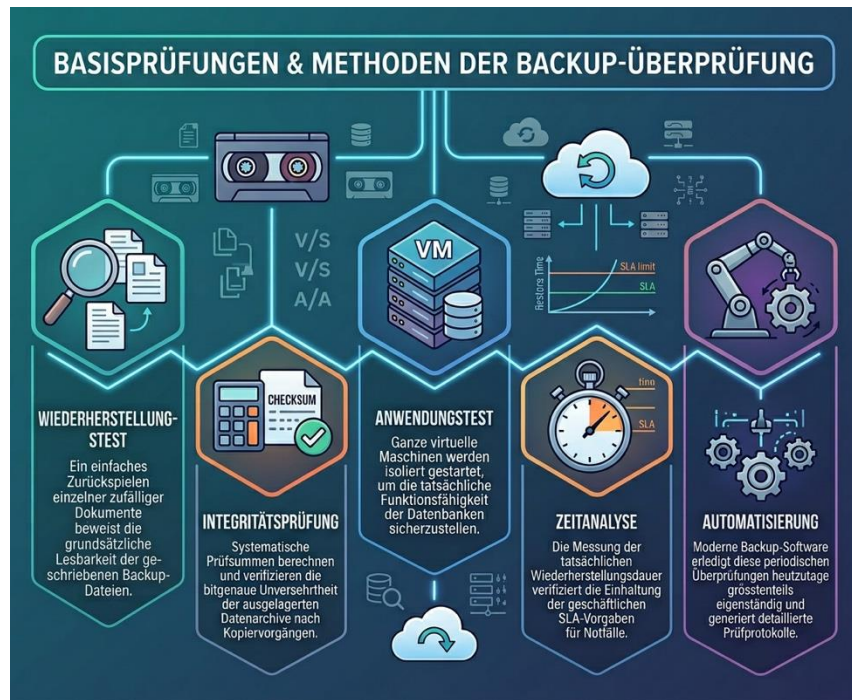
Unveränderbarkeit: Spezielle Immutability-Speicher verhindern das nachträgliche Verschlüsseln oder vorsätzliche Löschen von geschriebenen kritischen Archivdaten.

Null-Fehler-Toleranz: Ein Backup ist nur nützlich, wenn die spätere Wiederherstellung garantiert vollumfänglich fehlerfrei funktioniert.

Verifikation: Automatisierte Skripte prüfen jedes erstellte Backup auf Fehlerfreiheit, um die Null-Fehler-Strategie verlässlich umzusetzen.

Prüfung, Testing und die 3-2-1 Regel

Testverfahren für Backups



Wiederherstellungstest: Ein einfaches Zurückspielen einzelner zufälliger Dokumente beweist die grundsätzliche Lesbarkeit der geschriebenen Backup-Dateien.

Integritätsprüfung: Systematische Prüfsummen berechnen und verifizieren die bitgenaue Unversehrtheit der ausgelagerten Datenarchive nach Kopiervorgängen.

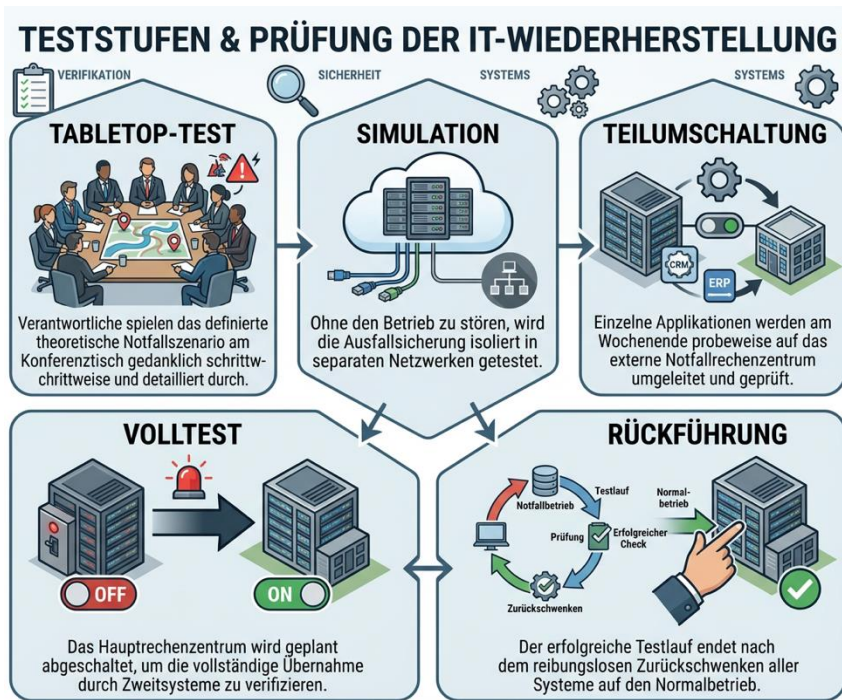
Anwendungstest: Ganze virtuelle Maschinen werden isoliert gestartet, um die tatsächliche Funktionsfähigkeit der Datenbanken sicherzustellen.

Zeitanalyse: Die Messung der tatsächlichen Wiederherstellungsdauer verifiziert die Einhaltung der geschäftlichen SLA-Vorgaben für Notfälle.

Automatisierung: Moderne Backup-Software erledigt diese periodischen Überprüfungen heutzutage grösstenteils eigenständig und generiert detaillierte Prüfprotokolle.

Prüfung, Testing und die 3-2-1 Regel

Testverfahren für Disaster Recovery



Tabletop-Test: Verantwortliche spielen das definierte theoretische Notfallszenario am Konferenztisch gedanklich schrittweise und detailliert durch.

Simulation: Ohne den Betrieb zu stören, wird die Ausfallsicherung isoliert in separaten Netzwerken getestet.

Teilumschaltung: Einzelne Applikationen werden am Wochenende probeweise auf das externe Notfallrechenzentrum umgeleitet und geprüft.

Volltest: Das Hauptrechenzentrum wird geplant abgeschaltet, um die vollständige Übernahme durch Zweitsysteme zu verifizieren.

Rückführung: Der erfolgreiche Testlauf endet nach dem reibungslosen Zurückschwenken aller Systeme auf den Normalbetrieb.

Prüfung, Testing und die 3-2-1 Regel

Kontrollmechanismen im Alltag



Backup-Logs: Tägliche Fehlermeldungen in Protokollen müssen von der IT-Abteilung systematisch analysiert und behoben werden.

Kapazitätsmonitoring: Warnsysteme melden frühzeitig drohende Speicherengpässe, bevor ein wichtiges Backup wegen Platzmangel unerwartet fehlschlägt.

Medienverwaltung: Die Rotation und der sichere physische Transport von Magnetbändern erfordern lückenlose manuelle Dokumentationen.

Virenskans: Speicherpools müssen periodisch auf ruhende Schadsoftware überprüft werden, um saubere Wiederherstellungen zu garantieren.

SLA-Tracking: Die Verfügbarkeit ausgelagerter Cloud-Ressourcen wird laufend gegen die vertraglich zugesicherten garantierten Leistungskennzahlen abgeglichen.

Prüfung, Testing und die 3-2-1 Regel

Auditierung von Notfallplänen

FORTLAUFENDE PFLEGE & ÜBERWACHUNG DES SICHERHEITSKONZEPTS



Aktualität: Veränderungen im Netzwerk müssen zwingend zeitnah in das bestehende theoretische Disaster-Recovery-Konzept übernommen werden.

Personalwechsel: Neue IT-Mitarbeitende benötigen entsprechende Einschulungen in die dokumentierten Abläufe der spezifischen betrieblichen Notfallprozesse.

Externe-Audits: Unabhängige Prüfer zertifizieren die Einhaltung rechtlicher Aufbewahrungsfristen und die absolute Wirksamkeit implementierter Sicherheitsmassnahmen.

Risikobewertung: Neue Cyber-Bedrohungen erfordern eine kontinuierliche Anpassung der etablierten Sicherungsstrategien an die veränderte Bedrohungslage.

Dokumentenlenkung: Veraltete Notfallhandbücher müssen systematisch eingezogen und durch eine korrekte aktuelle Fassung ersetzt werden.

Prüfung, Testing und die 3-2-1 Regel

Fallbeispiel Ransomware Recovery



Schadenserkennung: Monitoring-Tools bemerken ungewöhnliche Verschlüsselungsaktivitäten und trennen den infizierten Server sofort vom restlichen Firmennetzwerk.

Analysephase: Forensik-Experten identifizieren den exakten Angriffszeitpunkt, um das letzte garantiert saubere Datenbackup zu finden.

Bereinigung: Die befallenen Systeme werden komplett formatiert und mit sauberen Basisinstallationen völlig neu aufgebaut.

Wiederherstellung: Die validierten Offline-Kopien werden nun sicher auf die frisch aufgesetzten Applikationsserver fehlerfrei zurückgespielt.

Lessons-Learned: Eine anschließende detaillierte Untersuchung deckt bestehende Schwachstellen auf und optimiert die zukünftige Präventionsstrategie.

Prüfung, Testing und die 3-2-1 Regel

Praktische Umsetzung der Teststrategie



Testkalender: Ein strikter Jahresplan definiert exakte Zeitpunkte für verschiedene Arten von Simulationen und Überprüfungen.

Budgetierung: Ausreichende zeitliche und personelle Ressourcen müssen zwingend für diese komplexen Tests freigegeben werden.

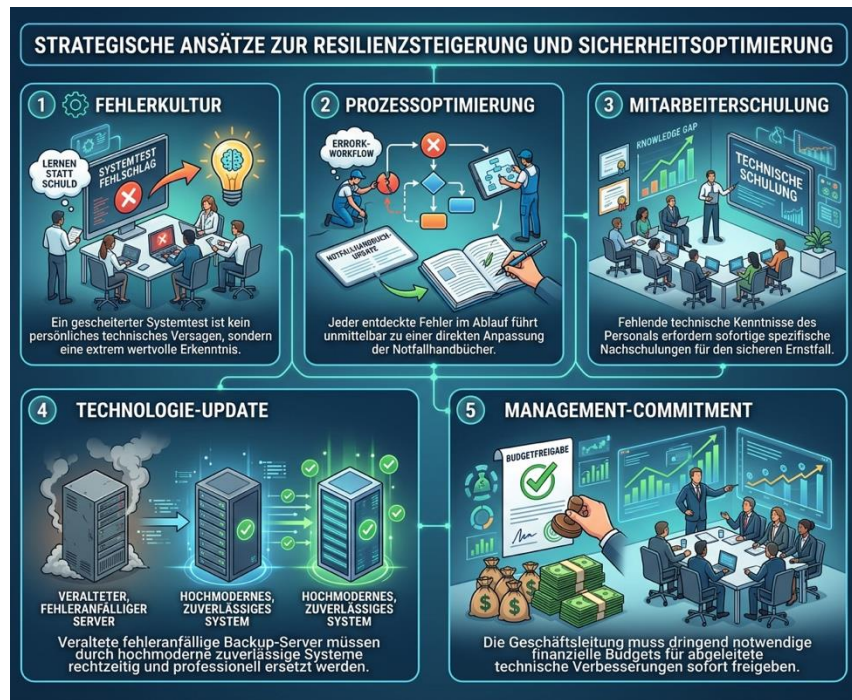
Realismus: Szenarien müssen aktuelle und realistische Bedrohungen abbilden, um falsche Sicherheit effektiv zu vermeiden.

Isolation: Sämtliche Wiederherstellungstests erfolgen in abgeschotteten Netzwerkbereichen, um Störungen der laufenden Produktivsysteme zu verhindern.

Dokumentation: Jeder durchgeführte Testlauf liefert ein schriftliches Protokoll mit erkannten Mängeln und verbindlichen Massnahmen.

Prüfung, Testing und die 3-2-1 Regel

Fehlerkultur und kontinuierliche Verbesserung



Fehlerkultur: Ein gescheiterter Systemtest ist kein persönliches technisches Versagen, sondern eine extrem wertvolle Erkenntnis.

Prozessoptimierung: Jeder entdeckte Fehler im Ablauf führt unmittelbar zu einer direkten Anpassung der Notfallhandbücher.

Mitarbeiterschulung: Fehlende technische Kenntnisse des Personals erfordern sofortige spezifische Nachschulungen für den sicheren Ernstfall.

Technologie-Update: Veraltete fehleranfällige Backup-Server müssen durch hochmoderne zuverlässige Systeme rechtzeitig und professionell ersetzt werden.

Management-Commitment: Die Geschäftsleitung muss dringend notwendige finanzielle Budgets für abgeleitete technische Verbesserungen sofort freigeben.

Gruppenaufgabe 3 (20 Minuten)

Prüfung, Testing und die 3-2-1 Regel

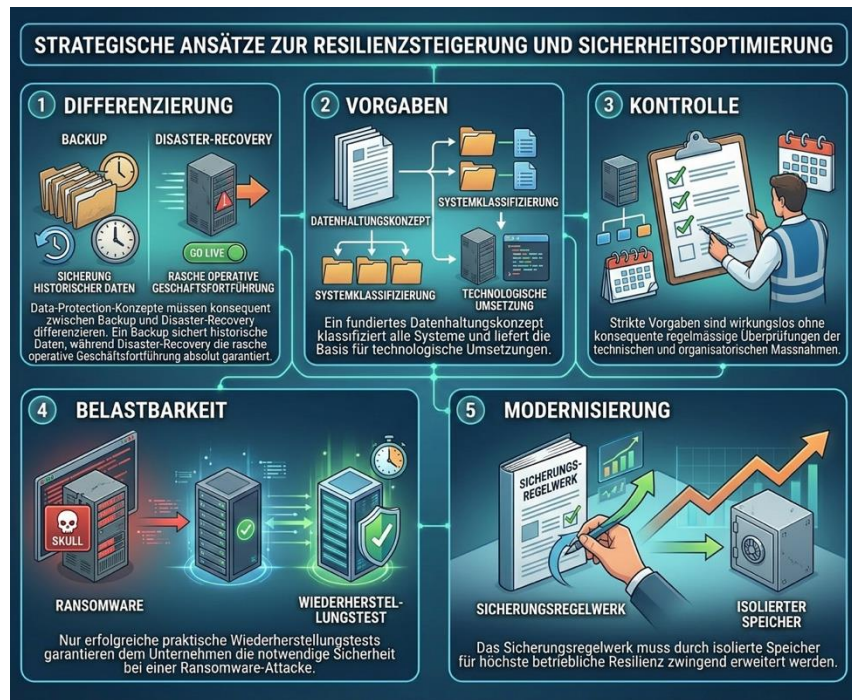
Szenario: Die «SwissMediCare AG», ein regionaler Gesundheitsverbund, wurde Opfer einer schweren Ransomware-Attacke. Die IT-Abteilung stellte mit Entsetzen fest, dass das Backup-System ebenfalls verschlüsselt wurde. Nun beauftragt Sie die Klinikleitung, die bestehende Sicherungsarchitektur schonungslos zu analysieren, ein zukunftsicheres 3-2-1-1-0 Konzept zu entwerfen und einen konkreten Testplan aufzubauen, damit ein solches Desaster nie wieder geschieht.

Arbeitsauftrag: Skizzieren Sie für die «SwissMediCare AG» das neue 3-2-1-1-0 Sicherungskonzept, indem Sie die Speichermedien und Standorte konkret benennen. Entwickeln Sie anschliessend einen pragmatischen Testkalender für das kommende Jahr, der aufzeigt, wann welche Art von Test (Restore, Tabletop, Volltest) durchgeführt wird, ohne den Klinikbetrieb zu gefährden.

Ergebnis: Präsentieren Sie Ihr Architektur-Konzept (als Diagramm oder Stichwortliste) und den Jahres-Testkalender in Form eines strukturierten Flipcharts. Dauer der Vorstellung: max. 4 Minuten.

Zusammenfassung

Kernaussagen Unit 4



Differenzierung: Ein Backup sichert historische Daten, während Disaster-Recovery die rasche operative Geschäftsführung absolut garantiert.

Vorgaben: Ein fundiertes Datenhaltungskonzept klassifiziert alle Systeme und liefert die Basis für technologische Umsetzungen.

Kontrolle: Strikte Vorgaben sind wirkungslos ohne konsequente regelmäßige Überprüfungen der technischen und organisatorischen Massnahmen.

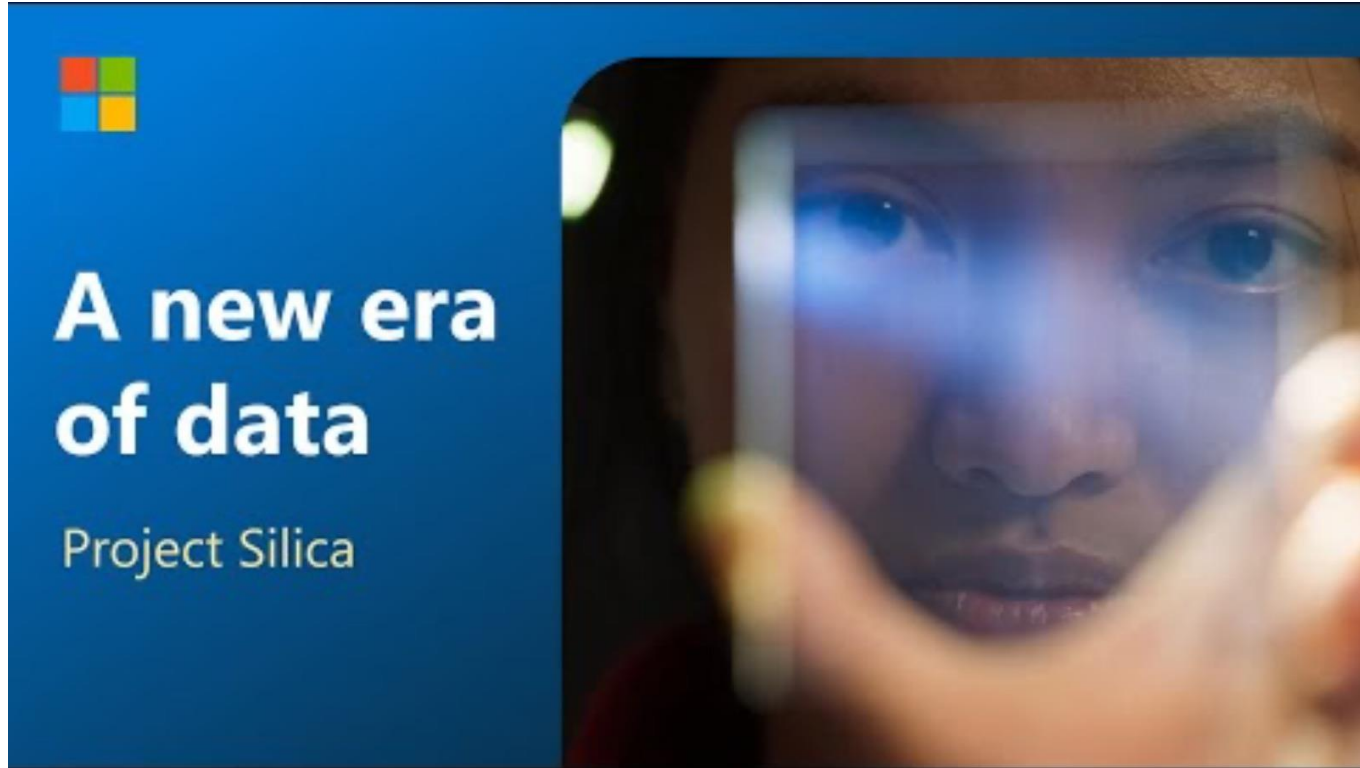
Belastbarkeit: Nur erfolgreiche praktische Wiederherstellungstests garantieren dem Unternehmen die notwendige Sicherheit bei einer Ransomware-Attacke.

Modernisierung: Das Sicherungsregelwerk muss durch isolierte Speicher für höchste betriebliche Resilienz zwingend erweitert werden.

Microsoft Project Silica

Saving data into voxels for next 10 years

ipso!



Fragen?

ipso!



Bildquelle: Pixabay